🔑 Solucionario del docente — CampusShop

Material **solo para el profesor**. Incluye cómo explotar cada reto y el fix exacto. La versión ya corregida y con las 16 pruebas en verde está en `parche-solucion/`. Para comprobarla:

```
cd docente/parche-solucion
pytest -v        # 16 passed
```

> Las banderas son falsas y están pensadas para que el alumno demuestre el acceso.

---

01 · Inyección SQL

Explotar. Usuario `admin' --`, contraseña cualquiera. La consulta vulnerable es `... WHERE username = 'admin' --' AND password = '...'`: el `--` comenta la verificación. Buscador: `' UNION SELECT id, username, password, '1' FROM usuarios --` → expone los hashes MD5.

Causa raíz. `campusshop/rutas/auth.py` y `tienda.py` concatenan el texto del usuario en el SQL.

Fix. Consulta parametrizada y verificación del hash en Python:

```
usuario = conn.execute("SELECT * FROM usuarios WHERE username = ?",
(username,)).fetchone()
if usuario is None or not verificar_password(password, usuario["password"]): ...
```

Buscador: `WHERE nombre LIKE ? OR descripcion LIKE ?` con `(patron, patron)`.

02 · XSS

Explotar. Reseña con `<img src=x onerror=alert(document.cookie)>` (almacenado); buscar `<script>alert(1)</script>` (reflejado); `?msg=<b>hola` pintado con `innerHTML` (DOM).

Causa raíz. `|safe` en `buscar.html`/`producto.html`, `innerHTML` en `app.js`, cookie sin `HttpOnly`.

Fix. Quitar `|safe` (Jinja escapa por defecto), usar `textContent`, cookie `HttpOnly`, y cabecera `Content-Security-Policy: script-src 'self'` (en `main.py`).

03 · Inyección de comandos

Explotar. En `/admin/diagnostico`, host = `127.0.0.1; cat flag.txt`.

Causa raíz. `subprocess.run(f"ping -c 1 {host}", shell=True)`.

Fix. Validar que `host` es una IP (`ipaddress.ip_address`) y ejecutar con lista de argumentos sin shell: `subprocess.run(["ping","-c","1","-W","1",host])`.

04 · IDOR

Explotar. Sesión de `ana`, `GET /api/facturas/1003` (factura de Luis).

Causa raíz. No se comprueba el dueño del recurso.

Fix. `if factura["usuario_id"] != usuario["id"]: raise HTTPException(403)`.

05 · Falta de idempotencia

Explotar. `python exploits/carrera_cupon.py <token> BIENVENIDA 10`. La comprobación "¿ya lo usaste?" y el `INSERT` están separados por un `sleep`: varias peticiones pasan la comprobación antes de que la primera registre el canje → saldo multiplicado.

Causa raíz. Patrón *check-then-act* (TOCTOU) sin atomicidad.

Fix. `UNIQUE (usuario_id, codigo)` en la tabla `canjes` y dejar que la base decida: `INSERT` dentro de `try/except sqlite3.IntegrityError → 409`.

06 · CSRF

Explotar. Con sesión abierta, abrir `atacante/index.html`; el formulario auto-enviado cambia el correo porque el navegador adjunta la cookie.

Causa raíz. Sin token anti-CSRF y cookie sin `SameSite`.

Fix. Token HMAC ligado a la sesión (`token_csrf`/`csrf_valido` en `auth.py`), campo oculto en el formulario, validación en `POST /perfil/email`, y cookie `SameSite=Lax`.

07 · Autenticación y sesiones débiles

Explotar. `python exploits/romper_md5.py <hash>` sobre los hashes del reto 01.

Causa raíz. `hashlib.md5` sin sal; cookie insegura; sesión que no se regenera.

Fix. `hashlib.scrypt` con sal (o bcrypt/Argon2), comparación con `hmac.compare_digest`, nuevo id de sesión al iniciar sesión.

08 · SSRF

Explotar. Preview de `http://127.0.0.1:9001/latest/meta-data/iam/credenciales`.

Causa raíz. `urllib.request.urlopen(url)` con URL arbitraria del usuario.

Fix. Lista blanca de dominios + resolver el host y rechazar IP privadas/loopback/ metadatos (`_destino_es_privado`), permitir solo `http/https`.

09 · Path traversal

Explotar. `/descargas?f=../../.env`.

Causa raíz. `FileResponse(CARPETA / f)` sin validar.

Fix. `ruta = (CARPETA / f).resolve()` y comprobar `str(ruta).startswith(str(CARPETA)+"/")`.

10 · Configuración y datos expuestos

Explotar. `/api/productos/99999` → traza con el `SECRET_KEY`; CORS `*`.

Causa raíz. `debug=True`, secreto en el código, CORS abierto, sin cabeceras.

Fix. `debug=False`, secreto desde variable de entorno, CORS a `localhost`, manejador global de excepciones que oculta la traza, y cabeceras (CSP, `X-Content-Type-Options`, `X-Frame-Options`, `Referrer-Policy`).

Mapa pruebas → reto

Prueba (`tests_seguridad/test_seguridad.py`)	**Reto**
`test_sqli_login_*`, `test_sqli_buscador_*`	01
`test_xss_buscador_*`, `test_xss_resenas_*`	02
`test_inyeccion_comandos_*`	03
`test_idor_*`, `test_factura_propia_*`	04
`test_cupon_no_se_puede_canjear_*`	05
`test_csrf_*`, `test_cookie_de_sesion_*`	06
`test_contrasenas_no_se_guardan_en_md5`	07
`test_ssrf_*`	08
`test_path_traversal_*`, `test_descarga_legitima_*`	09
`test_error_no_expone_*`, `test_cors_*`	10